

SHODAN QUERIES

For Exposed AI & ML Infrastructure

A Reference Guide for Security Researchers

Version 2.1 • April 2026 • NuClide

DISCLAIMER: These queries are provided for authorized security research, threat hunting, and defensive assessment only. Accessing systems you do not own or have authorization to test is illegal. Use responsibly.

How to Read This Document

Every query in this reference is tagged with an exposure tier indicating the expected severity of a positive hit. Tiering lets you triage a Shodan result set without re-deriving risk for every entry.

Tier	Meaning	How to use
T1	Unauthenticated by default	Service ships with no auth, or trivially-bypassed auth. A positive hit is typically a live, interactive target. Treat as immediately actionable.
T2	Requires misconfiguration	Service has auth by default but is commonly deployed without it, or has known auth-bypass CVEs. Positive hits need one additional probe to confirm exposure.
T3	Recon / fingerprint only	Identifies the presence of the service. Does not indicate auth status. Use for inventory, trend analysis, and pivoting.

A note on fingerprint drift

Favicon hashes, banner strings, and default ports shift between releases. Queries in this reference were spot-checked in April 2026 and are dated per section. If a query returns nothing 6+ months after the section date, verify the fingerprint against the current release before assuming the service has disappeared from the index.

What changed in v2

v2.0 added four new sections (RAG Stacks & Self-Hosted AI, Image Generation, AI Code Assistants, MCP Servers), expanded Container / Orchestration Infrastructure to cover k8s, kubelet, etcd, and Docker Registry v2, tagged every query with an exposure tier, and added Appendix A — a CVE cross-reference for queries where the exposure is the vulnerability.

v2.1 folds in a new Object Storage & Artifact Stores subsection under Vector Databases (MinIO, Harbor, image registries where AI models, vectors, and snapshots live), adds ClickHouse / Cassandra / txtai / Feast / Tecton entries, introduces GPT4All / NVIDIA NIM / AutoGen coverage, and appends a terminology primer below for readers newer to the stack.

Terminology Primer

Shorthand for the stack. Skip this page if you already live in it.

Term	Meaning
Artifact Store	Where trained models, weights, embeddings, and datasets actually live on disk. In self-hosted AI, this is almost always MinIO or S3. Compromise here means exfiltrating the model itself, not just the inference endpoint.
Feature Store	Centralized repository of ML features used for both training and serving. Feast and Tecton are the common names. Rare on Shodan, but a positive hit leaks the feature definitions that power production models.
GraphRAG / Knowledge Graph	Hybrid retrieval architecture combining a vector database with a graph database for relationship-aware retrieval. Neo4j + a vector store is the common pairing.
MCP (Model Context Protocol)	2025–2026 standard for connecting LLMs to tools, filesystems, and databases. The protocol was designed for stdio transport but deploys increasingly over HTTP/SSE — which is where exposure happens. See section 10.
OLAP + Vector	Hybrid analytical databases (ClickHouse, Cassandra 5.x+) that handle both classical OLAP queries and semantic vector search. Shows up in analytics-heavy AI stacks.
LLMjacking	2024-coined term for attacks that hijack exposed LLM endpoints or leaked API keys to run inference on someone else's provider bill. MCP servers and exposed LiteLLM proxies are primary targets.

Contents

1. LLM Orchestration Platforms
2. Vector Databases (incl. Object Storage & Artifact Stores — new)
3. Model Serving & Inference
4. Training, Fine-Tuning & Experiments
5. AI Gateways, Proxies & Monitoring
6. Agent Frameworks
7. RAG Stacks & Self-Hosted AI Apps
8. Image Generation & Diffusion
9. AI Code Assistants
10. MCP Servers
11. Credential Leaks & Misconfigs
12. Container & Orchestration Infrastructure
13. Backup / Snapshot Exposure
14. GPU & Compute Dashboards
15. Fingerprinting Canaries
- A. Appendix: High-Severity CVE Cross-Reference

1. LLM Orchestration Platforms

Section verified: April 2026

Flowise

Shodan Query	Tier	Notes
title:"Flowise" port:443	T3	Basic fingerprint, mixed auth status
"Flowise" "Express" port:3000	T2	Default port, often deployed without auth
http.html:"Low-code LLM apps builder"	T3	HTML title fingerprint
"Flowise" "chatflows" port:3000 401	T3	Auth enabled, confirms instance
"X-Powered-By: Express" "/api/v1" "chatflow"	T2	Flowise fingerprint — see CVE-2024-36420

CVE note: CVE-2024-36420 (auth bypass via path traversal) affects Flowise < 1.8.2. Exposed pre-auth instances are RCE candidates, not just info disclosure.

Other Orchestrators

Shodan Query	Tier	Notes
"Dify" port:80 "LLM"	T3	Dify fingerprint
"LangFlow" port:7860	T2	Often deployed unauth
"LangChain" port:8000	T3	Library fingerprint, app varies
"Haystack" port:8000 "pipeline"	T3	
"AutoGPT" port:8000	T2	
"Open WebUI" port:3000	T2	Auth possible, often disabled
"text-generation-webui" port:7860	T1	Rarely deployed with auth
"LocalAI" port:8080	T1	No auth by default
"Ollama" port:11434	T1	No auth support — exposure = full access
"LiteLLM" port:8000	T2	Proxy, master key often leaked in env
"AnythingLLM" port:3001	T2	Known auth bypass history
"Jan" port:1337	T3	Desktop app, rare server exposure
http.title:"Create Llama App"	T2	LlamaIndex default UI (common RAG starter)
http.favicon.hash:-1404538293	T3	LlamaIndex favicon fingerprint
"private gpt" port:8080 OR port:8001	T2	PrivateGPT local RAG app
http.title:"Clawdbot Control"	T1	OpenClaw / Clawdbot agent control UI
port:18789 "openclaw" OR "clawdbot"	T1	OpenClaw gateway — shell, browser, email access
"Chainlit" port:8000 OR port:8080	T2	Popular conversational UI layer on LangChain

OpenClaw / Clawdbot: This is not a passive reconnaissance target. A publicly reachable OpenClaw gateway is an agent with shell execution, browser automation, email send, and calendar write on whoever deployed it. Treat positive hits as live compromise surface, not data disclosure.

Prompt / Chain Management

Shodan Query	Tier	Notes
"PromptFlow" port:8080 "Microsoft"	T3	
"n8n" port:5678 "workflow"	T2	AI workflow automation, RCE history
"LangGraph" "studio" port:8123	T3	
"Rivet" port:4567	T3	Desktop app, server mode uncommon

2. Vector Databases

Section verified: April 2026

ChromaDB

Shodan Query	Tier	Notes
"chroma" port:8000 "api/v1"	T1	Pre-0.5 versions default to no auth
"/api/v1/heartbeat" "nanosecond"	T1	Most reliable Chroma fingerprint
"chroma" "0.4" port:8000	T1	Pre-auth default era
"chromadb" "/api/v2" port:8000	T2	Newer multi-tenant, auth optional
"/api/v1/collections" "ChromaDB" -401	T1	No auth confirmed
"chroma" "/openapi.json" port:8000	T2	Full API spec exposed
"Server: uvicorn" "/api/v1/collections"	T3	ChromaDB fingerprint

```
{"nanosecond heartbeat": 1713384722842816000}
```

What a T1 Chroma heartbeat response looks like. No auth, full API reachable.

Qdrant

Shodan Query	Tier	Notes
"qdrant" port:6333 "/collections"	T1	No auth by default
"qdrant" port:6333 "/dashboard"	T1	Web dashboard, full read/write
"qdrant" "/telemetry" port:6333	T2	Version + config disclosure
"qdrant" "points" "vectors" port:6333	T1	
"qdrant" "snapshots" port:6333	T1	Downloadable full-DB backups
http.title:"Qdrant Dashboard"	T3	

Weaviate

Shodan Query	Tier	Notes
"weaviate" port:8080 "/v1/schema"	T1	Anonymous access enabled by default
"weaviate" port:8080 "/v1/objects"	T1	
"weaviate" port:8080 "/v1/meta"	T2	Version + module disclosure
"weaviate" port:8080 "/v1/nodes"	T2	Cluster topology
"weaviate" port:8080 "/v1/backups"	T2	Backup enumeration
"weaviate" "modules" "text2vec-openai"	T2	Reveals OpenAI embedder configured (key stored server-side, not returned)

Shodan Query	Tier	Notes
"weaviate" "modules" "generative-openai"	T2	LLM key configured server-side
http.title:"Weaviate Console"	T3	

Milvus

Shodan Query	Tier	Notes
"milvus" port:19530	T1	gRPC API, auth optional
"milvus" port:9091 "/api/v1/health"	T3	
"milvus" port:9091 "/metrics"	T2	Prometheus metrics leak
"milvus" "Attu" port:8000	T1	Milvus admin GUI
http.title:"Attu" "Milvus"	T1	
"milvus" port:2379 "etcd"	T2	Metadata store exposed
"milvus" "MinIO" port:9000	T2	Object storage — raw vectors

Elasticsearch / OpenSearch

Shodan Query	Tier	Notes
"elasticsearch" port:9200 "/_cat/indices" "vector"	T2	
"elasticsearch" "8." port:9200 "dense_vector"	T3	v8+ native vector
"elasticsearch" "knn" port:9200	T3	
"elasticsearch" port:9200 "/_cluster/health"	T1	Cluster discovery
"kibana" port:5601 "embeddings"	T2	
"opensearch" port:9200 "knn"	T3	
"opensearch-dashboards" port:5601	T2	

PostgreSQL + pgvector

Shodan Query	Tier	Notes
"PostgreSQL" port:5432 "pgvector"	T3	Most installs auth-gated
"Supabase" port:5432	T3	Ships with pgvector
"pgAdmin" port:5050	T2	Often default creds
"Neon" "postgres" port:5432 "vector"	T3	
"Timescale" port:5432 "pgvector"	T3	

Redis Vector Search

Shodan Query	Tier	Notes
"Redis" port:6379 "search" "FT.SEARCH"	T2	
"Redis Stack" port:6379	T3	
"RedisInsight" port:8001	T2	Web GUI, auth optional
"Redis" port:6379 -"AUTH" -"NOAUTH"	T1	No password set

Other Vector DBs

Shodan Query	Tier	Notes
"Vespa" port:8080 "/document/v1"	T2	
"typesense" port:8108 "/collections"	T3	API key required
"typesense" port:8108 "/keys"	T2	API key enumeration attempt
"marqo" port:8882 "/indexes"	T2	
"lancedb" port:8000	T3	

Shodan Query	Tier	Notes
"surrealdb" port:8000 "/sql"	T2	
"arangodb" port:8529 "/_api/collection"	T2	
http.title:"ArangoDB Web Interface"	T3	
"Zilliz" port:9091	T3	
"MongoDB" port:27017 "vector"	T3	
"MongoDB" port:27017 -"auth"	T1	Unauth MongoDB
"mongo-express" port:8081	T2	Web admin, default creds common
"clickhouse" port:8123 "vector" OR "similarity"	T2	ClickHouse OLAP + vector hybrid (analytics stacks)
"cassandra" port:9042 "vector"	T3	Apache Cassandra 5.x+ vector extensions
"txtai" port:8000	T2	Lightweight embeddings / semantic search DB

Graph Databases / Memory

Shodan Query	Tier	Notes
"Neo4j" port:7474 "browser"	T2	Default creds neo4j/neo4j common
"neo4j" port:7474 "graph" OR "cypher"	T2	GraphRAG / knowledge graph workloads
"Dgraph" port:8080 "/admin"	T2	
"dgraph" "ratel" port:8000	T2	Web UI
"memgraph" "query" port:7687	T3	In-memory graph DB, common in agent memory
"Mem0" port:8000	T2	AI memory store

Object Storage & Artifact Stores

Vector databases are the search layer. Object storage is where the models, embeddings, raw documents, training datasets, and DB snapshots actually live on disk. Milvus, Weaviate, and most RAG pipelines back onto MinIO or S3 by default. A compromised bucket is typically a higher-impact finding than the index in front of it.

Shodan Query	Tier	Notes
"MinIO" port:9000	T2	S3-compatible store — default backing for Milvus/Weaviate/RAG
"Server: MinIO" OR title:"MinIO Browser" port:9000	T1	Console / browser UI — often zero auth
"MinIO" "bucket" OR "objects" port:9000	T1	Exposed bucket listing — models + vectors
"MinIO Console" port:9001	T2	
"MinIO" port:9000 -"auth"	T1	Public MinIO — object storage free-for-all
"Docker Registry" "/v2/" port:5000	T1	Anonymous catalog read = full image list
"registry/2.0" "/v2/_catalog" -"unauthorized"	T1	Open catalog, pull access typically follows
"harbor" port:80 OR port:443	T2	Harbor registry — enterprise AI model containers
http.title:"Harbor"	T2	
port:51000 OR port:55000 "Docker Registry"	T2	Non-default registry ports, same exposure class

Triage note: Anonymous /v2/_catalog read ≠ anonymous push. But anonymous pull of internal images leaks entire codebases, build-time secrets in layer history, and the full supply chain of whatever ships from that registry. Rate severity on *read* vs. *push* separately before escalating. See §12 for Docker daemon and container runtime exposure (distinct from the artifact store).

3. Model Serving & Inference

Section verified: April 2026

Inference Servers

Shodan Query	Tier	Notes
"Triton Inference Server" port:8000	T2	
"/v1/models" "openai" port:8000	T1	OpenAI-compatible API, no auth by default
"vLLM" port:8000	T1	No native auth
"TGI" "text-generation-inference" port:8080	T1	
"llama.cpp" port:8080	T1	
"koboldcpp" port:5001	T1	
"/v1/chat/completions" port:8000	T1	Any OpenAI-compatible endpoint
"/v1/embeddings" port:8000	T1	
port:1234 "/v1/models"	T1	LM Studio (very common local inference)
port:8000 "openai" "model"	T1	vLLM / any OpenAI-compatible with model list
port:8080 "llama" "completion"	T1	llama.cpp server (enhanced fingerprint)
port:4891 "GPT4All"	T1	GPT4All desktop LLM server
"NVIDIA NIM" port:8000	T2	NVIDIA NIM inference microservices (2026 deployments)

```
GET /v1/models HTTP/1.1 {"object":"list","data":[{"id":"meta-llama/Llama-3.1-70B-Instruct",  
"object":"model","created":1713300000,"owned_by":"vllm"}]}
```

Typical vLLM response on an exposed port. Model name reveals what's hosted; /v1/chat/completions on the same port is reachable with no auth.

Embedding / Reranking

Shodan Query	Tier	Notes
"TEI" "text-embeddings-inference" port:8080	T1	
"infinity" "embedding" port:7997	T1	
"Jina" "embeddings" port:8080	T2	
"Cohere" "rerank" port:8000	T3	
"sentence-transformers" port:8080	T1	

4. Training, Fine-Tuning & Experiments

Section verified: April 2026

Fine-Tuning / Training

Shodan Query	Tier	Notes
"Axolotl" port:8080	T2	
"unsloth" port:7860	T2	
"OpenLLM" port:3000 "bentoml"	T2	
"BentoML" port:3000 "/models"	T2	
"Ray" "dashboard" port:8265	T1	ShadowRay — CVE-2023-48022, unauth RCE, tens of thousands unpatched
"Ray Serve" port:8000 "deployments"	T1	Same cluster = same RCE surface
"Determined AI" port:8080 "experiments"	T2	
"ClearML" port:8008 "projects"	T2	
"SageMaker" "notebook" port:8443	T2	
"Lightning AI" port:7501	T3	
"LLaMA-Factory" port:7860	T2	WebUI fine-tuning, often public
"feast" OR "feature store" port:6566	T2	Feast feature store — rare on Shodan, high-value when found
"tecton" OR "feature platform"	T3	Enterprise feature store

Ray dashboard is the single highest-severity query in this reference. CVE-2023-48022 (ShadowRay) is unauthenticated RCE via the job submission API, actively exploited since disclosure, and the patch requires operator action (not automatic). A Ray dashboard on the public internet should be treated as already-compromised infrastructure until proven otherwise.

ML Experiment / Pipeline Tools

Shodan Query	Tier	Notes
"MLflow" port:5000 "experiments"	T1	Unauth MLflow — see CVE-2024-37052 through -37060 (RCE via model deserialization)
"MLflow" "registered-models" port:5000	T1	Model registry write access
"mlflow" "artifacts" port:5000	T1	Artifact store — trained models + experiment outputs
"Kubeflow" port:8080 "pipeline"	T2	
"Airflow" "DAG" port:8080	T2	RCE via DAG authoring if write access
"Jupyter" port:8888 "notebook"	T1	Token-based auth, frequently empty
"Gradio" port:7860	T2	Often public by design — authority depends on app

Shodan Query	Tier	Notes
"Streamlit" port:8501	T2	Frequently internal dashboards left public

Annotation / RLHF / Eval

Shodan Query	Tier	Notes
"Argilla" port:6900	T2	
"Label Studio" port:8080 "label"	T2	Labeled datasets often sensitive
"Promptfoo" port:3000	T3	
"DeepEval" port:8000	T3	

5. AI Gateways, Proxies & Monitoring

Section verified: April 2026

AI Gateway / Proxy

Shodan Query	Tier	Notes
"LiteLLM" "proxy" port:4000	T2	Master key in env — check section 11
"AI Gateway" port:8787 "Cloudflare"	T3	
"Kong" "ai-proxy" port:8000	T2	
"Portkey" port:8787	T3	
"Helicone" port:8080	T2	

LLM Observability / Monitoring

Shodan Query	Tier	Notes
"Langfuse" port:3000	T2	Logs every prompt/response — high-value PII leak
"Langsmith" port:1984	T2	
"Phoenix" "Arize" port:6006	T2	Trace data, often contains prompt history
"Prometheus" "/metrics" "llm"	T2	

Document Loaders / Parsers

Shodan Query	Tier	Notes
"Unstructured" port:8000 "/general/v0"	T2	
"Apache Tika" port:9998	T2	SSRF history
"Docling" port:8000	T3	
"LlamaParse" port:8000	T3	

6. Agent Frameworks

Section verified: April 2026

Autonomous Agents

Shodan Query	Tier	Notes
"SuperAGI" port:3000	T2	
"AgentGPT" port:3000	T2	
"BabyAGI" port:8080	T2	
"MetaGPT" port:8000	T2	
"OpenDevin" port:3000	T2	Full dev environment — shell/file/git access
"SWE-agent" port:8000	T2	
"Devika" port:1337	T2	
"GPT Researcher" port:8000	T3	
"Phidata" port:8000	T3	
"Clawdbot" OR "OpenClaw" port:18789	T1	2026 mass-exposure agent framework — shell, browser, email, calendar
"PrivateGPT" port:8080	T2	Local RAG agent (often zero auth) — see also §7
"AutoGen" OR "microsoft autogen" port:8000	T2	Microsoft AutoGen multi-agent framework

Agent framework exposure is a different class of finding. A reachable agent is not just data disclosure — it is a delegated-authority system acting on behalf of its operator. OpenClaw, OpenDevin, and similar frameworks have shell, browser, email, and calendar primitives. An unauthenticated hit is the operator's hands on your keyboard.

7. RAG Stacks & Self-Hosted AI Apps

New in v2 · Section verified: April 2026

Self-hosted RAG stacks accumulate enterprise document sets as part of normal use. An exposed instance is a document store — the content is the value, the model is the pivot.

Shodan Query	Tier	Notes
"h2oGPT" port:7860	T2	Self-hosted RAG, auth optional
"Verba" port:8000	T2	Weaviate-backed RAG UI
"Danswer" OR "Onyx" port:3000	T2	Enterprise search over connected sources
"Quivr" port:5050	T2	Personal/team second-brain RAG
"Letta" OR "MemGPT" port:8283	T2	Stateful agent with persistent memory
"Khoj" port:42110	T2	Personal AI with email/calendar/notes ingestion
"RAGFlow" port:80 OR port:8080	T2	Deep-document RAG engine
"FastGPT" port:3000 "fastgpt"	T2	
"LibreChat" port:3080	T2	Multi-provider chat UI, often unauth
"Open WebUI" "signup" port:3000	T1	First-user-becomes-admin pattern

The signup-becomes-admin pattern (Open WebUI, LibreChat, some Danswer deploys) means the first visitor to an exposed instance is promoted to admin of every subsequent user's conversations. Frequently unnoticed because the operator set a password on their own account and assumed the instance was protected.

8. Image Generation & Diffusion

New in v2 · Section verified: April 2026

Image generation stacks are deployed at massive scale on consumer GPU hardware, frequently with `--listen 0.0.0.0` set as the default by unofficial install scripts. Custom-trained LoRAs and checkpoint files on these hosts often include private subject data.

Shodan Query	Tier	Notes
"ComfyUI" port:8188	T1	Default install listens on all interfaces, no auth
http.title:"ComfyUI" OR product:"ComfyUI"	T1	Title/product fingerprint
"comfyui" port:8188 OR port:5984	T1	aiohttp backend, both common ports
"Stable Diffusion" port:7860	T1	AUTOMATIC1111 WebUI
"AUTOMATIC1111" port:7860	T1	
http.title:"Stable Diffusion"	T1	
"InvokeAI" port:9090	T2	
"Fooocus" port:7865	T1	
"SwarmUI" port:7801	T1	
"SD.Next" port:7860 "vlad"	T1	
"Forge" "Stable Diffusion" port:7860	T1	

ComfyUI custom nodes are an arbitrary Python execution surface. An exposed ComfyUI with the ComfyUI-Manager node (extremely common) allows remote installation of additional custom nodes, which is RCE by design.

9. AI Code Assistants

New in v2 • Section verified: April 2026

Self-hosted code assistants index proprietary source code to produce completions. Exposure of the assistant backend leaks the indexed codebase.

Shodan Query	Tier	Notes
"Tabby" OR "TabbyML" port:8080	T2	Self-hosted code completion, indexes private repos
http.title:"Tabby"	T3	
"Cody" "sourcegraph" port:7080	T2	Self-hosted Cody
"Continue" port:65432	T3	Continue.dev server mode
"Refact" port:8008	T2	
"FauxPilot" port:5000	T2	
"LocalPilot" port:8080	T2	
"bigcode" "/v2/models" port:8080	T3	

10. MCP Servers

New in v2 · Section verified: April 2026

Model Context Protocol servers expose tool surfaces — filesystem read, shell, database, internal APIs — for consumption by LLM clients. When operators expose MCP over HTTP/SSE rather than stdio, the tools become available to anyone who connects.

Shodan Query	Tier	Notes
"modelcontextprotocol" port:3000	T1	MCP SSE transport, no auth default
"mcp" "/"sse" "message" port:3000	T1	MCP server over SSE
"mcp" "tools/list" port:8080	T1	JSON-RPC MCP transport
"server-filesystem" "mcp"	T1	Filesystem MCP exposed — host file access
"mcp-server-" "sse" port:8000	T2	
"FastMCP" "uvicorn" port:8000	T2	Python MCP server framework
"mcp-proxy" port:8080	T2	stdio-to-HTTP bridge, extends exposure surface

MCP over HTTP is the 2026 wave. The protocol was designed for stdio (in-process transport) but the ecosystem pushed toward HTTP/SSE for remote access. Operators wiring internal tools — shell, database, filesystem — into an MCP server and exposing it without auth is the same failure pattern as unauthenticated RPC from the 1990s, with a new label.

11. Credential Leaks & Misconfigs

Section verified: April 2026

Exposed API Keys

Shodan Query	Tier	Notes
"OPENAI_API_KEY" port:8000	T1	Env var leaked in banner/error page
"sk-" "openai" port:3000	T2	OpenAI classic key format
"sk-proj-" port:3000 OR port:8000	T1	OpenAI project keys (newer format)
"ANTHROPIC_API_KEY"	T1	
"gsk_" OR "GROQ_API_KEY" port:8000	T1	Groq API keys (fast-growing in 2026)
"AIzaSy" OR "GOOGLE_API_KEY" "generativelanguage"	T1	Gemini / Google AI keys
"hf_" OR "HF_TOKEN" port:8080	T1	Hugging Face token
".env" "API_KEY" port:8000	T1	Exposed .env file
http.html:".env" ("OPENAI" OR "ANTHROPIC" OR "GROQ")	T1	.env files leaking multiple providers

Reporting note: Keys surfaced via Shodan are already exposed to the index and to anyone who paid for a Shodan subscription. Rotation is the fix; reporting to the key owner is the disclosure. Do not test the key against the provider API — that crosses the line from passive recon into credentialed access.

12. Container & Orchestration Infrastructure

Expanded in v2 · Section verified: April 2026

Modern AI stacks deploy container-first and k8s-first. The orchestration layer underneath the AI services is often the softer target — and compromise there gives you every workload on the cluster for free.

Docker Runtime

Shodan Query	Tier	Notes
"Docker" port:2375 "api"	T1	Unauth Docker daemon — container escape + host RCE
"Portainer" port:9000	T2	Default creds / signup-becomes-admin

Artifact stores (Docker Registry v2, Harbor, MinIO) moved to §2 under Object Storage & Artifact Stores. This section covers container runtime and orchestration surface only.

Kubernetes

Shodan Query	Tier	Notes
port:6443 "kubernetes" "unauthorized"	T3	API server reachable, auth enforced
port:6443 "/api/v1" -"unauthorized"	T1	Anonymous API access — full cluster read
port:10250 "kubelet"	T1	Anonymous kubelet = exec into any pod = cluster-wide RCE
port:10255 "kubelet"	T1	Read-only kubelet, pod/node enumeration
port:2379 "etcd"	T1	Unauth etcd = full cluster state, including secrets
"etcd" "v3" port:2379	T1	
"Rancher" port:8443	T2	
"k3s" port:6443	T3	
"Kubernetes Dashboard" port:30000	T2	Exposed dashboard, skip-login option historically

Kubelet on 10250 with anonymous access enabled is functionally equivalent to cluster-wide RCE. The /exec and /run endpoints allow arbitrary command execution inside any pod on the node. This is still seen in the wild at material volume.

Supporting Infrastructure

Shodan Query	Tier	Notes
"Consul" port:8500 "/v1/catalog"	T1	Service discovery — full topology
"Vault" port:8200 "/v1/sys/health"	T3	Auth required; reachable surface for attacks

MinIO moved to §2 Object Storage & Artifact Stores.

13. Backup / Snapshot Exposure

Section verified: April 2026

Shodan Query	Tier	Notes
"qdrant" "/snapshots" port:6333	T1	Downloadable .snapshot files — full vector DB
"milvus" "MinIO" port:9000 "bucket"	T1	Raw vectors in object storage
"chroma" "/persist" port:8000	T2	Persistent directory exposure
"weaviate" "/v1/backups" port:8080	T2	
"elasticsearch" "/_snapshot" port:9200	T2	
"/var/lib/docker" "overlay2"	T2	Container layer paths leaking
"backup.tar" OR "dump.sql" port:80	T1	HTTP-served backup files

14. GPU & Compute Dashboards

Section verified: April 2026

Shodan Query	Tier	Notes
"NVIDIA DCGM" port:9400 "/metrics"	T2	
"nvidia-smi" port:8080	T2	
"RunPod" port:8888	T2	
"Vast.ai" port:8080	T2	
"GPUSock" port:80	T2	

15. Fingerprinting Canaries

Section verified: April 2026

Favicon Hashes

Shodan Query	Tier	Notes
http.favicon.hash:-1294819032	T3	Gradio
http.favicon.hash:1279780014	T3	Streamlit
http.favicon.hash:-1848965666	T3	Jupyter
http.favicon.hash:-1404538293	T3	LlamaIndex / Create Llama App
http.favicon.hash:348721092	T3	Clawdbot / OpenClaw agent UI

Favicon hashes drift with version bumps. Hashes here were valid in April 2026; for long-term use, pair a hash with a text fingerprint to catch the service even when the icon changes.

Generic AI Service Detection

Shodan Query	Tier	Notes
"Server: uvicorn" "/docs" "FastAPI"	T3	Any FastAPI ML service
"/v1/chat/completions" port:8000	T1	OpenAI-compatible endpoint
"/v1/embeddings" port:8000	T1	
"model" "temperature" "max_tokens" port:8000	T2	OpenAI-style request schema
"LM Studio" OR "lmstudio" port:1234	T1	LM Studio desktop server exposure
http.html:"api/tags" port:11434	T1	Ollama model list (no auth)
http.html:"mcp.json" OR "Model Context Protocol"	T2	MCP servers — heavily targeted in LLMjacking campaigns
"aiohttp" product:"ComfyUI"	T1	Quick ComfyUI product-level filter

Appendix A — High-Severity CVE Cross-Reference

New in v2 • Section verified: April 2026

Queries where the exposure *is* the vulnerability — matching a banner is already enough to flag the host for patching or further investigation. Prioritize these when triaging bulk results.

Service	CVE	Class	Notes
Ray Dashboard	CVE-2023-48022	Unauth RCE	ShadowRay. Job submission API accepts arbitrary commands. Fix requires explicit --disable-usage-stats and auth config.
MLflow	CVE-2024-37052 ... 37060	RCE via deserialization	Chain of model-loading vulnerabilities. Any exposed MLflow with write access to the model registry is RCE.
Flowise	CVE-2024-36420	Auth bypass	Path traversal grants unauth access to chatflow config, API keys. Affects < 1.8.2.
AnythingLLM	Multiple 2024-2025	Auth bypass / SSRF	Recurring auth and SSRF issues — treat any exposed instance as suspect until version verified.
Ollama	CVE-2024-37032 (Problama)	Path traversal → RCE	Fixed in 0.1.34. Combined with the no-auth default this is remote code execution on any unpatched host.
n8n	Multiple RCE via node code	RCE by design	Workflow nodes can execute JS/shell. Write access = RCE. No CVE because it's the intended behavior.
Jupyter	Token-bypass misconfig	Unauth RCE	--NotebookApp.token="" is the historic footgun. Notebooks are shell.
ComfyUI + Comfy UI-Manager	Design-level RCE	RCE via custom nodes	Remote installation of custom Python nodes is intended behavior. Exposure + Manager = RCE.
Kubelet (10250)	Anonymous auth enabled	Cluster-wide RCE	/exec on any pod. Still seen in the wild at material volume.
Docker daemon (2375)	Design-level	Container escape + host RCE	Mount host filesystem into a privileged container, write to /host/etc/cron.d, etc.
etcd (2379)	Anonymous access	Full cluster secret disclosure	All Kubernetes secrets, config, tokens readable. Effectively cluster takeover.

End of Reference — v2.0, April 2026

For the defensive companion to this reference — aimap, a scanner for AI/ML infrastructure defenders can run against their own networks — see: github.com/Nicholas-Kloster/aimap